

Incident Response Investigation: Cryptocurrency Miner Infection on Windows Workstation

Overview

This investigation was conducted as part of an Incident Response engagement involving a potentially compromised Windows workstation.

The objective was to identify the source of malicious activity, determine how the malware was introduced, identify persistence mechanisms, uncover command-and-control (C2) communications, and recommend remediation actions.

Scenario

A Security Operations Center (SOC) analyst detected suspicious activity on a Windows workstation and escalated the case to the Incident Response Team (IRT) for further investigation.

The investigation focused on determining:

- The malicious process running on the system
- The malware's communication channel
- The initial infection vector
- The persistence mechanism
- The location of malicious files
- Appropriate remediation actions

Investigation Methodology

The investigation followed the standard incident response lifecycle:

1. Identification
2. Analysis
3. Containment
4. Eradication
5. Recovery
6. Lessons Learned

System artifacts, network activity, registry entries, and suspicious files were analyzed to reconstruct the attack chain.

Malicious Process Identification

Analysis of running processes revealed a suspicious executable

Process Name: 32th4ckm3.exe

Command-and-Control Communication

Network analysis revealed that the malware was communicating with an external command-and-control server.

IP Address: 45[.]33[.]32[.]156

Port: 42424

Analysis

The outbound connection indicates that the malware maintained communication with external infrastructure, potentially for:

1. Receiving commands
2. Reporting mining statistics
3. Downloading updates
4. Exfiltrating system information

Initial Infection Vector

Further investigation identified a malicious Microsoft Word document containing embedded macros.

Document Name: invoice n. 65748224.docm

The use of a .docm file indicates the presence of macros capable of executing code on the victim system.

This technique is commonly used in phishing campaigns where users are tricked into opening documents and enabling macros.

Malware Delivery Mechanism

The malicious macro downloaded the miner from the following location: hxxp[:]//]172[.]233[.]61[.]246/

The download was performed using a built-in Windows utility: certutil

Attackers frequently abuse certutil.exe because it is a legitimate Windows utility that can download remote files while helping malware evade traditional security controls.

This is a classic Living-off-the-Land Binary (LOLBin) technique.

Investigation identified the location where the malicious executable was stored.

Path: C:\Users\TryCleanUser\AppData\Local\Temp\2

Persistence Mechanism

The malware established persistence through the Windows Run Registry Key.

Value Name: DefaultApp

The Run Registry Key enables programs to execute automatically whenever a user logs in. By creating the DefaultApp registry value, the malware ensured that it would automatically restart after system reboots, maintaining persistence on the compromised host.

Attack Chain Reconstruction

The investigation suggests the following attack sequence:

1. The victim opened the malicious document:
invoice n. 65748224.docm
2. The embedded macro executed malicious code.
3. The macro abused certutil.exe to download the payload from:
hxxp[:]//]172[.]233[.]61[.]246/
4. The malware was saved to:
C:\Users\TryCleanUser\AppData\Local\Temp\2
5. The malicious process 32th4ckm3.exe was launched.
6. The malware established persistence using the Run Registry Key (DefaultApp).
7. The malware connected to: 45[.]33[.]32[.]156:42424 to communicate with its
command-and-control infrastructure

Skills Demonstrated

- Incident Response
- Malware Analysis
- Windows Forensics
- Registry Analysis
- Network Analysis
- Threat Hunting
- Persistence Detection
- SOC Operations
- IOC Identification
- Malware Remediation